

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

Access Control Policy

AIR-ISMS-POL-002 | Version 1.0 | May 2026

Document Control

Document ID	AIR-ISMS-POL-002
Version	1.0
Status	Approved
Classification	Internal
Document Owner	Head of IT Operations
Reviewed By	Head of Security & Compliance
Approved By	Chief Executive Officer
Approval Date	May 2026
Review Cycle	Annual
Next Review Due	May 2027

1. Purpose

This policy defines AIR's requirements for managing access to its information assets, systems, and infrastructure. It establishes controls over who can access what, under what conditions, and how that access is granted, modified, and removed.

Access control is a primary defence against both external threats and internal misuse. Given AIR's responsibility for Restricted government-affiliated research data and proprietary AI technologies, ensuring that access is appropriate, time-limited, and consistently reviewed is a core operational obligation.

2. Scope

This policy applies to all systems, platforms, and information assets within the AIR ISMS scope. It applies to all employees, contractors, research collaborators, and any third party with access to the above systems, regardless of location or working arrangement.

3. Access Control Principles

All access decisions at AIR are guided by the following principles:

Least Privilege: Users are granted only the minimum access required to perform their role. Default access is no access. Access is added only when justified and approved.

Need to Know: Access to Restricted and Confidential information requires a documented business reason, in addition to role-based entitlements. Classification level alone does not confer automatic access.

Segregation of Duties: No individual should have the ability to initiate and approve the same privileged action. Administrative and operational roles are separated where feasible.

Access by Exception: Elevated or temporary access may be granted on a time-limited basis with formal approval. All exceptions are documented and reviewed.

Accountability: Shared accounts are prohibited. Every action on AIR systems must be attributable to a specific individual account.

Regular Review: Access rights are reviewed at defined intervals. Rights not confirmed as current are revoked automatically.

4. User Access Lifecycle

4.1 Access Provisioning: New Joiners and Role Changes

Access is provisioned only upon receipt of a completed and approved Access Request. No access is granted on informal or verbal instruction.

Step	Action	Responsible	Timeframe
1	HR notifies IT Operations of new joiner or role change via the approved HR system workflow.	HR / Department Head	Before start date
2	IT Operations creates or modifies the Entra ID account and assigns role-based access groups aligned to the job function.	IT Operations	Day 1 or within 24 hours of notification
3	Department Head or Asset Owner approves any access beyond standard role entitlements, including access to Restricted assets.	Asset Owner	Before access is granted
4	IT Operations confirms provisioning is complete and access is logged in the Access Request record.	IT Operations	Within 24 hours of approval
5	New user completes mandatory security awareness training before receiving access to Restricted or Confidential systems.	Head of Security & Compliance	Within 30 days of joining

Standard role-based access is defined per job function in the Role Access Matrix, maintained by IT Operations and reviewed quarterly. Access beyond the matrix requires explicit Asset Owner approval.

4.2 Access Modification: Internal Moves

When a user changes role, department, or project assignment:

- The previous role's access entitlements are revoked within five working days of the change
- New access is provisioned following the same approval process as for new joiners
- The user's manager is responsible for initiating both the revocation and the new request
- Access from a previous role must never be accumulated

4.3 Access Deprovisioning: Leavers and Offboarding

Timely deprovisioning is one of AIR's highest-priority access control obligations. Incomplete offboarding is a known risk (RSK-005) and is treated with the same urgency as an active security incident.

Action	Responsible	Deadline
HR notifies IT Operations and Head of Security & Compliance of confirmed last working day (employee or contractor).	HR	At least 5 working days before last day where possible

IT Operations disables the Entra ID account.	IT Operations	Within 2 hours of last working day end
IT Operations revokes all active sessions, tokens, and application access.	IT Operations	Within 2 hours of account disable
IT Operations removes the user from all security groups, distribution lists, and shared access configurations.	IT Operations	Within 24 hours of departure
GitHub Enterprise access is removed from the airtech organisation.	IT Operations / AI Engineering	Within 24 hours of departure
Managed endpoint is collected, wiped, and re-provisioned.	IT Operations	Within 5 working days of departure
IT Operations confirms full deprovisioning via the Offboarding Checklist and records the completion date.	IT Operations	Within 5 working days of departure
Head of Security & Compliance conducts a spot-check of high-risk departures (Restricted data access, privileged accounts).	Head of Security & Compliance	Within 10 working days of departure

IMPORTANT: The 2-hour deprovisioning target applies to all leavers. For involuntary departures or any departure involving Restricted data access, account disable must occur simultaneously with the exit meeting. IT Operations must be pre-briefed by HR in these cases.

5. Authentication Requirements

5.1 Multi-Factor Authentication (MFA)

MFA is mandatory for all accounts with access to AIR systems.

Requirement	Detail
Scope	MFA is required for all Entra ID accounts, including employees, contractors and guest accounts.
Enforcement	MFA is enforced via Entra ID Conditional Access policies. Any authentication attempt without MFA is blocked.
Permitted methods	Microsoft Authenticator app (push notification or passkey). FIDO2 hardware security key for privileged accounts. Time-based one-time password (TOTP) authenticator app as fallback.
Prohibited methods	SMS one-time codes are not permitted as a primary MFA method due to SIM-swap and interception risks.
Legacy protocols	Legacy authentication protocols (Basic Auth, SMTP Auth without modern auth) are blocked organisation-wide.
Coverage monitoring	IT Operations reports MFA coverage as a percentage of all active accounts monthly to Head of Security & Compliance. Target: 100%.

5.2 Password Requirements

Where passwords are used as a credential layer alongside MFA, the following requirements apply:

- Minimum length: 14 characters
- Complexity: must include at least three of the following: uppercase, lowercase, number, special character
- Password history: last 12 passwords may not be reused
- Maximum age: 365 days. Passwords must be changed upon any suspected compromise, without waiting for expiry
- Banned passwords list: Entra ID Password Protection is enabled, blocking common and organisation-specific weak passwords
- Passwords must never be shared, written down, or stored in unencrypted files

5.3 Privileged Account Authentication

Accounts with administrative or elevated privileges are subject to stronger authentication requirements:

- Privileged accounts must use a FIDO2 hardware security key or Entra ID Privileged Identity Management (PIM) just-in-time activation, not standard MFA push notification
- Privileged sessions must be initiated from a managed, compliant device
- Administrative tasks must not be performed using day-to-day user accounts, separate privileged accounts are required for all administrative roles
- All privileged account activity is logged and retained for a minimum of 90 days

6. Privileged Access Management

Privileged access, including global administrator, subscription owner, security administrator, and equivalent roles, poses the highest risk to AIR's systems and data. The following controls apply to all privileged roles.

Control	Requirement
Just-In-Time Access	Permanent assignment of privileged roles is prohibited. All privileged access is activated via Entra ID Privileged Identity Management (PIM) on a time-limited, request-and-approve basis. Maximum activation duration: 4 hours.
Approval Workflow	Privileged role activation requires approval from the Head of IT Operations or Head of Security & Compliance. Approvals are logged automatically via PIM.
Minimum Number of Admins	The number of global administrators in the Entra ID tenant must not exceed four. Break-glass accounts are excluded and managed separately.
Break-Glass Accounts	Two emergency access accounts (break-glass) are maintained for use only when PIM and standard authentication are unavailable. Credentials are stored offline in a sealed physical envelope accessible only to the CEO and Head of IT Operations. Break-glass use triggers an immediate security review.
GitHub Administrative Access	GitHub Enterprise organisation owner role is limited to a maximum of two accounts. Repository admin access follows the same least-privilege model as cloud roles.
Azure RBAC	Azure subscriptions follow a role assignment model: Owner rights are restricted to IT Operations. All other teams use Contributor or Reader roles scoped to specific resource groups.
Audit Logging	All privileged role activations, approvals, and actions are logged in Entra ID audit logs and Azure Monitor. Logs are retained for a minimum of 12 months.

7. Contractor and Third-Party Access

AIR engages 25 contractors and research collaborators, many of whom require access to internal systems. Contractor access represents a heightened risk due to reduced visibility into contractor security practices and device posture.

7.1 Access Provisioning for Contractors

- Contractor access is requested by the sponsoring department head and approved by the relevant Asset Owner
- Contractors receive Entra ID guest or member accounts scoped to the systems they require, not generic shared accounts
- Access scope is documented in the contractor's onboarding record and reviewed before any extension of engagement

- Contractors must not be granted access to systems beyond the scope of their current engagement without a new approval
- All contractor accounts are tagged in Entra ID with the contractor type, sponsoring manager, and contract end date

7.2 Device Requirements for Contractors

Data Access Level	Device Requirement
Restricted data	AIR-managed device required. No personal device access permitted. If a managed device cannot be provided, access must be via AIR-managed Azure Virtual Desktop session only.
Confidential data	AIR-managed device strongly preferred. If personal device is used, it must pass an Entra ID device compliance check via Conditional Access. Non-compliant devices are blocked.
Internal data	Entra ID device compliance check enforced via Conditional Access. Unmanaged devices with no compliance signal are blocked from accessing Internal-classified systems.

7.3 Contractor Offboarding

Contractor offboarding follows the same timeline and checklist as employee offboarding (Section 4.3). The sponsoring department head is responsible for notifying HR and IT Operations at least five working days before the contractor's last day. Failure to notify within this window must be escalated to the Head of Security & Compliance.

8. Remote Access

AIR operates a hybrid working environment across three office locations and supports remote access for both employees and contractors. All remote access is subject to the following controls.

- Remote access to AIR systems is permitted only from managed, Intune-enrolled devices unless Azure Virtual Desktop is used as the access mechanism
- MFA is required for all remote sessions
- Conditional Access policies enforce device compliance checks before granting access to Restricted and Confidential systems from any location
- Remote access to on-premises Madrid HQ systems requires VPN connection authenticated via Entra ID
- Split-tunnelling on VPN connections is not permitted for sessions accessing Restricted data
- Users must not access AIR systems from public or shared computers (internet cafés, hotel business centres)
- Endpoint screen lock must activate after a maximum of 5 minutes of inactivity, this is enforced via Intune device configuration policy

9. Access Reviews

Access rights are reviewed regularly to ensure they remain current, appropriate, and consistent with the principle of least privilege.

Review Type	Scope	Frequency	Owner
Quarterly Access Review	All contractor and research collaborator accounts. All privileged role assignments in Entra ID PIM and Azure RBAC.	Quarterly (Feb, May, Aug, Nov)	IT Operations

Annual Access Review	All employee accounts and their assigned role groups. GitHub Enterprise organisation membership and repository access. All service accounts and their permission scopes.	Annual (May)	IT Operations / Asset Owners
Post-Incident Review	All accounts and access paths relevant to the incident scope.	Within 10 working days of incident closure	Head of Security & Compliance
Ad Hoc Review	Any account flagged as suspicious or associated with a departure, role change, or security alert.	Within 48 hours of trigger	IT Operations

Access rights not confirmed as current during a scheduled review are revoked automatically. Asset Owners must respond to access review requests within five working days. Non-responses are treated as a revocation.

10. Service Accounts and API Access

Service accounts and API keys used for system-to-system authentication must meet the following requirements:

- Service accounts must be created with the minimum permissions required for their function, not repurposed from existing user accounts
- API keys and secrets must not be stored in source code, configuration files committed to GitHub, or in plaintext. Azure Key Vault is the approved secrets management solution
- GitHub Enterprise secret scanning is enabled on all repositories. Any detected secret triggers immediate rotation and a security review
- Service account credentials are rotated at least annually, or immediately following any suspected compromise or personnel change that held knowledge of the credential
- All service accounts are documented in IT Operations' service account register, including owner, purpose, and last credential rotation date

11. Roles and Responsibilities

Role	Responsibility
Head of IT Operations	Owns this policy. Manages access provisioning, deprovisioning, and review processes. Maintains the Role Access Matrix. Reports MFA coverage monthly.
Head of Security & Compliance	Reviews this policy annually. Monitors access review completion. Escalates non-compliance. Conducts spot-checks on high-risk departures.
Asset Owners / Department Heads	Approve access requests beyond standard role entitlements. Initiate access provisioning and deprovisioning requests. Respond to access review requests within five working days.
HR	Notifies IT Operations of new joiners, role changes, and departures with the required notice period. Maintains the employee and contractor record.
All Employees and Contractors	Use only the access they have been granted. Report any suspected unauthorised access, account compromise, or access anomaly to IT Operations or the Head of Security & Compliance immediately. Do not share credentials under any circumstances.

12. Non-Compliance

Violations of this policy, including sharing credentials, bypassing MFA, retaining access after a role change, or failing to notify IT Operations of a departure within the required timeframe, are treated as

serious security incidents. Non-compliance may result in immediate access suspension, disciplinary action, or termination of employment or contract.

13. Review and Maintenance

This policy is reviewed annually by the Head of IT Operations and approved by the Chief Executive Officer. It will be reviewed immediately following any access control incident, significant organisational change, or change to AIR's technology environment.

Role	Name	Signature	Date
Document Owner	Head of IT Operations		May 20, 2026
Executive Approver	Chief Executive Officer		May 20, 2026